

ICS 33.030

CCS M 21

团体标准

T/TAF 209.2—2024

移动互联网应用程序（APP）合规开发管理 测评规范 第2部分：需求设计

Evaluation specification for compliance development of mobile
application—Part 2: Requirements design

2024-02-23 发布

2024-02-23 实施

电信终端产业协会 发布

目 次

前言 II

引言 III

1 范围 1

2 规范性引用文件 1

3 术语和定义 1

4 缩略语 2

5 需求设计概述与相关角色职责 2

 5.1 需求设计流程 2

 5.2 需求设计原则 2

 5.3 人员角色及相关职责 2

6 需求设计合规开发管理要求 2

 6.1 需求设计合规开发要求 2

 6.2 需求设计合规管理要求 3

7 需求设计合规开发管理测试方法 3

附录 A（资料性）移动互联网应用程序需求设计阶段合规开发管理参考 5

 A.1 需求阶段 5

 A.2 设计阶段 5

前 言

本文件按照GB/T 1.1—2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》的规定起草。

本文件是T/TAF 209《移动互联网应用程序（APP）合规开发管理测评规范》的第2部分。T/TAF 209已经发布了以下部分：

- 第1部分：总则；
- 第2部分：需求设计；
- 第3部分：功能测试；
- 第4部分：代码审计；
- 第5部分：对外接口管理；
- 第6部分：应用编程接口（API）管理；
- 第7部分：更新升级管理；
- 第8部分：数据使用管理；
- 第9部分：算法模型；
- 第10部分：人员能力；
- 第11部分：能力成熟度评估。

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别专利的责任。

本文件由电信终端产业协会提出并归口。

本文件起草单位：中国信息通信研究院、维沃移动通信有限公司、北京三星通信技术研究有限公司、华为终端有限公司、荣耀终端有限公司、小米通讯技术有限公司、北京快手科技有限公司、蚂蚁科技集团股份有限公司、北京微梦创科网络技术有限公司、北京三快科技有限公司、厦门美柚股份有限公司。

本文件主要起草人：赵盈洁、贾科、王淞鹤、吴越、李实、潘洁、赵晓娜、李辰淑、姚鹤、落红卫、王昕、林冠辰、任资政、邹庆、王芳、吴斌、黄鹏华。

引 言

为了确保在移动互联网应用程序开发管理过程中全流程的合规性,针对该流程中的移动互联网应用程序在需求、设计阶段的合规提出要求,让开发管理过程更加合规,以达到增强内部控制,对违规行为进行持续监测、识别、预警、防范、控制、化解合规风险的目的。

T/TAF 209旨在对APP开发流程、功能模块、工程管理等提出合规开发管理要求,拟由11部分构成。

- 第1部分:总则。目的在于给出规范移动互联网应用程序(APP)合规开发的总体原则和要求。
- 第2部分:需求设计。目的在于提出规范APP需求设计环节的相关合规开发要求。
- 第3部分:功能测试。目的在于规范移动互联网应用程序(APP)在合规开发阶段满足功能测试的标准要求。
- 第4部分:代码审计。目的在于规范APP代码审计过程,提升代码安全管理能力。
- 第5部分:对外接口管理。目的在于规范APP对外接口的合规开发和使用管理,提升合规能力。
- 第6部分:应用编程接口(API)管理。目的在于规范APP在开发过程中对于API的使用,提升合规能力。
- 第7部分:更新升级管理。目的在于规范APP合规开发在更新升级阶段的要求,提升APP更新升级管理能力。
- 第8部分:数据使用管理。目的在于规范APP在合规开发过程中数据使用的合规管理,提升数据使用合规管理能力。
- 第9部分:算法模型。目的在于规范APP合规开发在算法模型方面的要求,提升APP算法模型开发的合规管理能力。
- 第10部分:人员能力。目的在于规范APP在合规开发过程中的人员能力管理。
- 第11部分:能力成熟度评估。目的在于规范APP在合规开发管理过程中的能力成熟度评估。

移动互联网应用程序（APP）合规开发管理测评规范 第2部分：需求设计

1 范围

本文件规定了APP开发过程的需求设计阶段中的合规开发管理要求，以及对应的测试方法。

本文件适用于APP开发者的设计、生产活动，也适用于主管部门、第三方评估机构等组织对APP开发全过程中的需求设计阶段进行合规评估。

2 规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本文件必不可少的条款。其中，注日期的引用文件，仅该日期对应的版本适用于本文件；不注日期的引用文件，其最新版本（包括所有的修改单）适用于本文件。

T/TAF 209.1—2024 移动互联网应用程序（APP）合规开发管理测评规范 第1部分：总则

3 术语和定义

下列术语和定义适用于本文件。

3.1

移动互联网应用程序 mobile Internet application

可安装在移动智能终端内，能够利用移动智能终端操作系统提供的公开开发接口，实现某项或某几项特定任务的应用程序。

注：包含移动智能终端预置应用、小程序、快应用以及互联网信息提供者提供的可以通过网站、应用商店等应用分发平台下载、安装、升级的应用程序，简称 APP。

3.2

需求阶段 requirements phase

软件生存周期中的一个阶段，在此期间对软件产品的需求（如功能和性能方面的能力）进行定义并编织出相应的文档。

3.3

需求分析 requirements analysis

研究用户需要以得到系统、硬件或软件需求的定义的过程。

3.4

设计阶段 design phase

软件生存周期中的一段时间。在这段时间内，进行体系结构、软件组成部分、接口和数据的涉及，为涉及编制文件，并对其进行验证，以满足预定需求。

3.5

产品设计 product design

为使产品满足规定的需求而定义产品或其部件的体系结构、部件、接口和其他特征的过程。

4 缩略语

下列缩略语适用于本文件。

APP：移动互联网应用程序（Mobile Internet Application）

SDK：软件开发包（Software Development Kit）

5 需求设计概述与相关角色职责

5.1 需求设计流程

需求设计包括需求 and 设计两个阶段。需求阶段是整体产品研发流程中的起始环节，应依据“最小必要”、“合法合规”等个人信息安全原则，确定产品的个人信息保护和安全合规需求；设计阶段用于将需求转化为产品设计，从而达到后期落地的目的。

5.2 需求设计原则

为使产品服务能够满足合规性要求，在需求设计过程中应满足T/TAF 209.1—2024中的相关原则，以及以下原则：

- a) 全流程保护原则：在需求阶段，需将隐私合规相关内容融入需求中考虑，在设计阶段，需对相关内容进行持续跟踪，并确保隐私需求的完整实现。
- b) 用户中心原则：在需求设计过程中，以用户为中心设计产品服务的相关功能，帮助用户实现对个人信息更好的自主控制。

5.3 人员角色及相关职责

需求设计阶段的人员角色及相关职责要求如下：

- 需求分析人员：在满足安全合规规范的情况下，负责需求调研、需求收集、需求分析和需求规划工作，根据产品规划进行详细的需求分析，对产品的功能、流程进行细化，编制需求说明书。
- 产品设计人员：在满足安全合规规范的情况下，根据需求分析人员提供的需求说明书，进行产品的功能设计、交互方案设计等。
- 安全合规人员：负责评估相关需求说明书及方案设计等确保其符合合规要求，共同确定需求清单及方案设计。

6 需求设计合规开发管理要求

6.1 需求设计合规开发要求

在满足需求设计原则的情况下，还需考虑个人信息全生命周期的安全合规要求，并在需求设计阶段中就融入相关方案或设计中。

- a) 需求阶段通常划分为需求分析、需求评估以及需求确定三个部分：
 - 1) 需求分析是需求分析人员根据产品的功能需求清单，识别涉及的个人信息处理场景并分析个人信息处理需求，梳理产品需满足的相关合规要求，并识别可能存在的个人信息安全风险等过程；
 - 2) 需求评估是需求分析人员对个人信息处理需求和安全需求进行评估，发现可能存在的安全合规风险，评估要点包括但不限于预期的个人信息处理目的和处理方式是否合法正当、预期收集的个人信息对实现产品功能的必要性、是否存在对用户个人信息权益产生的影响及安全风险等过程；
 - 3) 需求确定中的需求需要安全合规人员确认满足合规性要求，其中不合规需求需要调整后再次评估，合规需求确认后输出产品合规需求。
- b) 设计阶段通常划分为安全设计、设计评估以及设计确定三个部分：
 - 1) 安全设计是产品设计人员针对产品合规需求，设计对应的合规功能实现方案，包括制定产品合规设计规范，明确安全合规功能设计要求，根据产品功能需求和产品合规需求，在开发流程、模块功能等设计中明确产品的合规处理设计等过程。
 - 2) 设计评估是产品设计人员根据产品需满足的合规要求，制定合规检查项，并对合规设计进行评估检查，发现可能存在的安全合规风险等过程。
 - 3) 设计确定中的设计需求安全合规人员确认满足合规性要求，其中不合规设计需要调整后再次评估，合规需求确认后输出产品合规设计。

6.2 需求设计合规管理要求

在需求设计阶段，应满足以下合规管理要求：

- a) 应对安全合规人员、需求分析/产品设计人员等角色进行分离设置；
- b) 建立完善的需求安全合规评估流程，对涉及到的需求进行全面的安全合规评估：
 - 1) 对需求本身进行相关安全风险评估；
 - 2) 接入的第三方组件及SDK应经过安全评估可用后再进行引入；
 - 3) 对采用的开源代码进行风险评估；
- c) 制定个人信息的访问控制策略，相应职责人员只能访问职责所必须的最小必要的个人信息，且仅具备完成职责所需的最少数据操作权限；
- d) 建立完善的个人信息操作审批流程，如进行批量修改、拷贝、下载等重要操作；
- e) 建立完善的个人信息操作留存机制，能够追溯工作人员对个人信息进行的操作；
- f) 建立完善的个人信息分类分级管理机制，能够对相关个人信息进行分级保护；

注：若企业有完善的个人信息分类分级管理机制，在APP需求设计阶段可复用该机制分级保护相关个人信息。

7 需求设计合规开发管理测试方法

对于需求设计过程中的合规开发管理的测试方法主要采用资料审查、技术验证和人员访谈对相关的开发及管理要求进行符合性评估，具体见表1。

表1 需求设计合规开发管理要求与测评方法对应关系表

要求条款	测评方法		
	资料审查	技术验证	人员访谈
5.2	-	-	√

表 1 需求设计合规开发管理要求与测评方法对应关系表（续）

要求条款	测评方法		
	资料审查	技术验证	人员访谈
5.3	—	—	√
6.1 a)	√	√	—
6.1 b)	√	√	—
6.2 a)	√	—	√
6.2 b)	√	√	—
6.2 c)	√	√	—
6.2 d)	√	√	—
6.2 e)	√	√	—
6.2 f)	√	—	√
注：“√”项为应采用的测试方法；“—”表示不适用。			



附录 A

(资料性)

移动互联网应用程序需求设计阶段合规开发管理参考

A.1 需求阶段

作为产品开发周期的第一个环节,每个项目在明确需求集合后均会对可能涉及的合规风险的需求点进行拆解和识别。经过安全和合规专家评审后,制定风险缓控措施和开发设计要点,并将结论纳入后续详细设计方案中,同时发起其它必要的评估流程。可参考以下步骤:

- a) 企业根据国内外法律法规及行业标准、客户安全需求、业界最佳实践等制定相关规范,对涉及到数据全生命周期、API接口、对外接口、数据使用、算法模型等多种场景提出明确要求,为业务需求分解提供指导。安全和合规专家协助产品经理依照改规范进行拆解和分析,确定潜在安全与隐私需求并随项目功能需求同步推进,确保项目需求落地的合规遵从性。
- b) 对于将要进入并集成到代码的外部能力,需建立完备的评估流程。通过资料收集建档、基础安全合规扫描、人工渗透分析以及迭代情况平台留存等节点保证引入技术能力的合规遵从性。

A.2 设计阶段

A 设计阶段

在项目架构设计阶段,架构师根据相应规范对产品开展安全架构设计和业务安全需求设计,出具包含保障架构安全性和合规性的设计方案后,需通过项目安全与合规专家评审。同时对判定为高风险功能场景的方案开展威胁建模,确保架构设计的风险最小化。通过建模分析及评审产生的设计方案形成后续验收阶段的测试用例,用以对安全设计及风险保护能力的验证。

- a) 在实践中,需要将隐私设计的7个原则(主动应对而非被动相应,隐私作为默认设置,隐私设计驱动,功能正和而不是零和,端到端安全和全生命周期保护,可见性、透明度、保持开放,尊重用户隐私、以用户为中心),贯穿整个产品的生命周期。
- b) 在设计阶段,通过系统化方法,对业务流程、产品、系统中涉及的个人信息收集、处理等活动开展风险识别、分析和评估。
- c) 从威胁建模、基础安全设计对架构进行分析,将架构设计存在的安全合规风险尽量全面的在设计阶段暴露出来,并对发现的风险制定相应的缓解措施。

参 考 文 献

- [1] GB/T 11457—2006 信息技术 软件工程术语



电信终端产业协会团体标准

移动互联网应用程序（APP）合规开发管理测评规范 第2部分：需求设计

T/TAF 209.2—2023

*

版权所有 侵权必究

电信终端产业协会印发
地址：北京市西城区新街口外大街28号
电话：010-82052809
电子版发行网址：www.taf.org.cn